

SOH · SOH_DID 사전 요청 자료 통합 작성안

작성일: 2026-09-17 | 기업 확인 전 초안 | 원본 요청서 1~51번 대응

두 작성안의 공통 답변은 통합하고, 서비스 계층별 구현 차이와 미확인 사항은 구분했습니다. 본문은 기업 입력란의 답변 기초자료이며, SOH_DID의 상세 API·데이터·키·배포 자료는 별첨 A~D에 보존했습니다. 원본 PDF와 기존 작성안은 변경하지 않았습니다.

검토 대상 구분: 'SOH API'는 Java/Spring Boot 구강건강 서비스와 관련 웹·AWS 구성, 'SOH_DID'는 Python/Flask 기반 DID·VC·VP 및 DChain 연계 API입니다. '공통'은 두 검토 범위에 함께 적용되는 답변입니다. DID는 식별자, VC는 검증 가능한 자격증명, VP는 자격증명의 제시 자료를 의미합니다.

통합 기준: 제공된 두 PDF와 대응 Markdown의 내용을 통합했습니다. 두 서버의 실제 운영 연결 주소·배포 버전·인증 경계는 이번 작업에서 확인하지 않았습니다. SOH API의 외부 토큰 서버가 SOH_DID의 특정 배포본이라는 전제는 운영 설정을 대조한 후 확정해야 합니다. 기본 설정값은 실제 운영값과 다를 수 있습니다.

확정 범위: 소스 검토 결과를 담은 초안이며 현재 운영 상태·보안 통제의 효과·기업 정책 보유 여부를 증명하지 않습니다. '확인 필요'는 '미보유' 또는 '아니오'를 뜻하지 않습니다. 별도 서식1·2·3·5·6·7과 운영 증적은 별도 확보가 필요합니다.

통합 시 구분한 핵심 사항

- 키 보관: SOH API의 지갑 키 AES-256-GCM 암호화와 SOH_DID의 로컬 JSON·DB 키 저장을 별도로 기술했습니다. 전체 경로가 암호화된다고 일반화하지 않았습니다.
- 접근 통제: SOH API의 JWT·역할 통제와 SOH_DID의 retrieve 전용 소유자 검사를 구분했습니다. Flask 전체 API에 동일한 인증·인가가 적용된 것으로 표현하지 않았습니다.
- 잔액·정합성: SOH API의 리워드 원장·중복 검사와 SOH_DID의 영상별 상태값(1)을 구분했습니다. 외부 거래와 양쪽 DB를 포함한 원자성·중복 방지·온체인 대사는 별도 확인 대상입니다.
- 체인 정보: SOH_DID 문서의 Mitum API 경로와 minic 기본값을 반영했습니다. 퍼블릭·프라이빗 구분, 실제 체인 ID·메인넷 여부·계약 주소는 확정하지 않았습니다.

기본 정보 · 1~6

1. 조직도

기업 확인 필요. 조직도에 개인정보보호책임자(CPO), 정보보호 담당 직위·부서 및 개인정보 취급 부서를 표시하여 별도 제출해야 합니다. 개발 저장소로 조직과 책임자를 확인할 수 없습니다.

2. 임직원 수

기업 확인 필요. 정규직 []명, 비정규직 []명, 총 []명.

3. 개발자·기술 인력 수

기업 확인 필요. 블록체인 []명, 백엔드 []명, 프론트엔드 []명, 인프라·운영 []명. 겸직 인원은 중복 집계 여부를 명시해야 합니다.

4. 보안 전담 인력 수

기업 확인 필요. 전담 []명, 겸직 []명, 겸직 담당 직무 [].

5. 정보보호·개인정보보호 담당자 유무

기업 확인 필요. 지정 여부 [], 담당 직위·부서 [].

6. 24×7 운영·관제 여부

기업 확인 필요. AWS 상시 가동 구성이나 SOH_DID의 systemd 자동 재시작 설정은 24시간 인력 관제를 입증하지 않습니다. 교대 관제, 외부 관제 계약, 담당자와 비상 연락 체계를 확인해야 합니다.

서비스·기술 구성 · 7~14

7. 블록체인 서비스 개요

SOH API

서비스명: SOH(Senior Oral Healthcare), 시니어 구강건강 관리 서비스.

구강체조 콘텐츠와 진도 관리, 구강 이미지 기반 치태·치은염 분석, 설문 및 맞춤 콘텐츠를 제공하며, DaeguChain·다대구 연동을 통해 DID 기반 사용자 연계와 지갑 관리, 구강체조 리워드 토큰 지급·회수 기능을 구현했습니다. 관리자 기능에는 사용자·진도·리워드 현황 및 블록체인 연동 로그 조회가 포함됩니다. 상품 수령 단계에는 리워드 회수 처리가 연계됩니다.

서비스 URL: <https://soh.thomabio.com> / API: <https://api.soh.thomabio.com/api>. 확인 자료는 README, 구강체조·리워드·다대구 연동 소스 및 관리자 화면입니다. 출시일 [기업 확인 필요], 실제 사용자 수 [기준일과 함께 기업 확인 필요].

SOH_DID

프로젝트명 SOH_DID. 로컬 DID 생성·조회·삭제, VC 발급·검증, VP 생성·검증, 대구체인 연계 지갑 생성, 토큰 생성·전송·회수·잔액 조회를 제공하는 Python Flask API이다. 영상별 토큰 지급 여부를 관리하는 DB 필드와 영상 시청 테스트 화면이 포함되어 있다. 공식 서비스명, 출시일, 실제 사용자 수는 기업 확인 필요. 근거: S1-S5, S7, S9.

8. 블록체인 유형

SOH API는 DaeguChain 및 외부 DID·토큰 서비스 API를 연계합니다. SOH_DID 검토본에는 DChain의 Mitum 경로 API, 기본 주소 <https://www.daegu.go.kr/daeguchain/v2/mitum> 및 기본 체인 설정 minic가 확인되어 있습니다. SOH_DID의 DID는 로컬 did:key 방식으로 별도 생성되며 체인 지갑 생성과 구분됩니다.

퍼블릭·프라이빗·컨소시엄 구분, 기반 플랫폼 버전, 실제 체인 ID, 운영 설정 및 메인넷·테스트넷 여부는 기업·체인 운영기관 확인 필요입니다. token-20-nft-721 명칭만으로 Ethereum 등 특정 체인으로 확정하지 않습니다.

9. 서비스 운영 단계

SOH API

저장소 문서에는 운영 서비스 주소와 prod 배포 체계가 정의되어 있습니다. 다만 실제 운영 상태와 연결 체인의 메인넷 운영 여부는 이번 작성에서 실시간 확인하지 않았으므로, 제출 시 서비스 운영 담당자 및 체인 제공사가 확정해야 합니다.

SOH_DID

코드 및 EC2 배포 예시는 확인되지만, 메인넷 운영/테스트넷/출시 예정 여부는 기업 확인 필요. 근거: S8.

10. 스마트컨트랙트 운영 여부 및 개수

두 검토 범위에 외부 체인 API를 통한 토큰 생성·조회·전송·승인·발행·소각 등의 연동 기능이 있으며, SOH API에는 NFT 관련 범용 API도 있습니다. SOH_DID는 컨트랙트 주소·공급량·응답 메타데이터를 DB에 저장합니다.

두 작성안 모두 자체 컨트랙트 소스·컴파일러·빌드 체계는 확인하지 못했습니다. 실제 배포 개수·주소, 소유·관리 주체 및 자체 개발 여부는 별도 확인해야 합니다. 로컬 Token 테이블 건수나 API 존재만으로 온체인 배포 수를 확정하거나 '0개'로 기입할 수 없습니다.

11. 지갑·수탁·키 관리 기능

SOH API

예. DID·리워드 지갑 생성 및 연계, 지갑 주소·리워드 거래 관리, 지갑 개인키 암호화 저장 기능이 구현되어 있습니다. SOH는 서버에서 사용자 지갑 개인키를 취급하는 구조이며, 저장 시 AES-256-GCM을 사용합니다. 토큰 회수 요청은 외부 토큰 서버로 운영자 개인키를 포함한 요청을 전달하며, holder 서명키 해석은 외부 서버에 의존합니다. 실제 서명 환경 및 수탁 책임 구분은 제공사와 확인해야 합니다.

SOH_DID

구현 있음. DID 키는 서버에서 Ed25519로 생성하고 체인 지갑은 외부 계정 생성 API로 발급한다. DID 키와 지갑 키를 서버 파일에 저장하며 DID 키는 MySQL에도 저장한다. 일부 체인 요청에 서버 소유자 키를 사용하고, 레거시 지갑 회수 시 저장된 지갑 키를 불러온다. 실제 수탁 서비스 해당 여부와 운영 보관 유형은 기업 확인 필요. 근거: S2, S3, S7. 상세: 별첨 C.

통합 해석: SOH API의 암호화 저장과 SOH_DID의 키 보관은 서로 다른 저장 지점입니다. SOH_DID의 평문 JSON·DB 저장 및 생성 응답의 키 포함 동작은 35번과 별첨 C를 함께 확인해야 합니다.

12. 주요 시스템 구성

SOH API

웹 프론트엔드(React·TypeScript·Vite, S3·CloudFront) → HTTPS API → ALB → 사설 앱 서브넷의 EC2 Auto Scaling Group(Spring Boot·Java 17) → 사설 DB 서브넷의 RDS MySQL 구성입니다. API는 외부 DaeguChain·DID·토큰 서비스와 연동합니다. Secrets Manager는 DB 자격증명 관리에 사용합니다. 서버 실가동 수량과 외부 체인 노드 수는 확인 필요합니다.

SOH_DID

테스트 웹(HTML/JavaScript) → Flask API → 외부 DChain HTTPS API로 연계하며, Flask는 MySQL과 로컬 DID/키 파일 저장소를 사용한다. Gunicorn/systemd 배포 예시가 있다. 실제 서버·DB·노드 수 및 네트워크 구성은 기업 확인 필요. 근거: S1-S9. 상세: 별첨 A.

13. 클라우드 사용 여부 및 사업자

SOH API

예. AWS를 사용하며, 백엔드 인프라 기준 리전은 서울(ap-northeast-2)입니다. 저장소상 주요 구성은 EC2, Auto Scaling, ALB, RDS MySQL, S3, CloudFront, VPC, NAT Gateway, IAM, Secrets Manager 등입니다. 개별 리소스의 현재 가동 수량은 별도 확인이 필요합니다.

SOH_DID

AWS EC2용 배포 예시가 저장소에 있다. 실제 AWS 사용 여부, 계정·리전·리소스 수 및 관리 주체는 기업 확인 필요. 근거: S8.

14. 노드 직접 운영 여부

두 검토 범위 모두 외부 DaeguChain/DChain API를 호출하는 구조이며, 직접 노드를 구동하는 배포·운영 설정은 확인되지 않았습니다. 기업의 별도 보유·위탁 운영 여부, 노드 수·유형·역할은 확인 필요합니다. 직접 운영하지 않는 것으로 확인되면 '아니오, 외부 제공사 API 이용'으로 기입할 수 있습니다.

개인정보 처리 · 15~18

15. 개인정보 처리 여부

예. SOH API는 회원가입·로그인, 기관별 사용자 관리, 다대구 인증, 구강건강·리워드 기능에서 개인정보를 처리합니다. SOH_DID도 사용자 식별자·DID·지갑 주소 등 사용자와 연결되는 데이터를 입력·저장합니다. SOH_DID로 전달되는 실제 개인정보 범위와 서비스 간 결합·제공 관계는 운영 데이터 흐름을 확인해 확정해야 합니다.

16. 처리하는 개인정보 유형

SOH API

이름, 전화번호, 생년월일, 성별, 로그인 식별자, 비밀번호 해시, 비밀번호 찾기 질문·답변, 소속 기관, DID, 다대구 CI의 해시, 지갑 주소, 로그인·서비스 이용 기록, 구강체조 진도·리워드 거래 기록 등을 처리합니다. 구강 이미지, 치태·치은염 분석 결과, 설문 응답 등 건강 관련 정보도 처리 대상입니다. 구강 이미지를 신원 식별용 생체정보로 사용한다고 확인된 것은 아닙니다. 항목별 보유기간·법적 분류·제3자 제공 범위는 실제 처리방침과 대조해야 합니다.

SOH_DID

DID, label/userIdentifier/id/user_id에서 받은 사용자 식별자, 계정 주소, 공개키·개인키, 생성시각, 영상별 토큰 지급 상태를 처리한다. VC 발급 요청의 claims는 임의 속성을 수용한다. DB에는 credential JWT·상태·유효기간 필드도 있으나 현재 로컬 VC 발급 라우트의 해당 DB 저장 호출은 확인되지 않는다. 이름·연락처·KYC·생체정보의 실수집 여부는 미확인이다. 개인키는 별도의 인증 비밀정보로 관리 대상이다. 근거: S2, S7.

17. 개인정보 처리방침

최신 승인본과 게시 URL 확인 필요. 서비스 주소는 <https://soh.thomabio.com> 이지만 이를 개인정보 처리방침 전용 URL로 대체할 수는 없습니다. 개인정보·건강정보·DID·지갑정보 처리, 외부 연동, 보유기간 및 파기 내용을 반영한 최신 원문을 기업에서 별도 제출해야 합니다.

18. 만 14세 미만 아동 대상 여부

서비스는 시니어 구강건강 관리를 목적으로 합니다. 그러나 목적만으로 아동 이용 배제를 확정할 수 없으므로 실제 가입 정책·연령 제한과 법정대리인 동의 운영 여부를 기업에서 확인해야 합니다.

정보보호 관리체계 · 19~22

19. 정보보호 정책·지침 보유 여부

SOH API의 AGENTS.md·README에 비밀값 기록 금지, DB 자격증명 관리, 배포 통제, 지갑 암호화 키 보존 등 개발·운영 규칙이 있습니다. SOH_DID 검토 범위에서는 승인된 정보보호 정책·지침을 확인하지 못했습니다. 기업 전체의 승인 정책 보유 여부, 문서명·승인일·적용 범위는 기업 확인 필요입니다. 개발 지침을 전사 정책이나 두 시스템 전체에 적용된 통제로 간주하지 않습니다.

20. 최근 1년 취약점 점검

기업 확인 필요. 최근 1년 점검 기관·기간·범위·결과 보고서와 조치 내역을 확인해야 합니다. SOH API의 보안 헤더·테스트와 SOH_DID의 회수 API 테스트 코드 존재만으로 공식 취약점 점검 수행을 입증할 수 없습니다.

21. ISMS·ISO27001 등 인증

기업 확인 필요. 인증명, 인증 범위, 유효기간 및 증빙 원본을 기준으로 작성해야 합니다.

22. 최근 3년 보안사고

기업 확인 필요. 사고 유무는 운영·보안 책임자의 확인과 사고대장에 근거해야 하며, 저장소에서 확인되지 않았다는 이유로 '없음'으로 기입하지 않습니다.

블록체인 점검 · 23~47

23. 블록체인 보안현황 조사서

별도 서식1이 제공되지 않아 공식 조사서 작성은 미완료입니다. 본 문서 7~16번, 24~46번과 SOH_DID 별첨 A~D를 기초자료로 사용할 수 있습니다. SOH API·SOH_DID·외부 체인 제공사의 책임과 점검 범위를 구분해 확정해야 합니다.

24. 점검 대상 목록

SOH API

웹: <https://soh.thomabio.com>. API: <https://api.soh.thomabio.com/api>. 관리자 화면: 사용자·진도·DID/리워드·연동 로그·토큰 관리 기능. 백엔드: 구강체조 리워드 지급·회수, 지갑·DID 연계, 다대구 로그인, 관리자 토큰 생성 및 범용 DaeguChain API.

지갑: 사용자 리워드 지갑과 토큰 운영자 지갑. 컨트랙트: 실제 사용 토큰명·컨트랙트 주소·체인 식별정보 확인 필요. 노드: 외부 연동 대상이며 운영 방식·대수 확인 필요. 서식2에는 활성 기능과 비활성·미사용 연동 API를 구분하고 실제 주소를 검증한 후 기입해야 합니다.

SOH_DID

Flask API, MySQL(DID/user/Token/keyValue), 로컬 DID/키 저장소, 외부 DChain 연계부, 소유자·사용자 지갑, 테스트 웹, EC2 서비스 설정을 후보 범위로 작성할 수 있다. 운영 URL, 컨트랙트·지갑 주소, 서버 수, 노드 운영 구분은 기업 확인 필요. 별첨 A 참고. 공식 서식2는 별도 필요.

25. 아키텍처·설계 자료

SOH API

보유 근거는 README와 infra/terraform, API 소스입니다. 서비스 흐름은 웹 → SOH API → DB 및 외부 DID·토큰 API입니다. 오프체인 처리에는 회원정보, 건강정보, 진도, 암호화된 지갑 개인키, 리워드 처리 상태와 연동 로그가 포함됩니다. 온체인 연계 대상은 토큰 컨트랙트·주소·전송 결과입니다. DID·VC의 실제 체인 기록 범위와 외부 서버 저장 범위는 제공사 확인 필요입니다.

회원·건강정보가 전부 온체인에 기록된다고 볼 근거는 없습니다. 반대로 외부 서비스까지 개인정보 온체인 기록이 전혀 없다고 보장할 근거도 없습니다. 외부 API 성공 응답 및 계약한 주소·토큰 매핑을 신뢰하는 경계가 있으므로 체인 확정 기준은 별도 명세가 필요합니다.

SOH_DID

저장소 구현을 토대로 별첨 A에 구성과 온체인·오프체인 데이터 구분을 작성했다. 이는 이번 검토에서 작성한 구현 설명이며 기존 승인 설계 문서로 간주하지 않는다. 체인 내부 저장 구조와 실제 네트워크 분리는 확인 필요.

26. 불변식·파라미터 명세

SOH API

자체 컨트랙트 명세는 확인되지 않았습니다. 참고 가능한 SOH 백엔드 제약은 사용자·토큰별 기존 지급 확인 및 idempotency key 사용, 완료된 리워드 여정의 추가 지급 차단, 실패 지급의 잔액 미반영, 성공 회수의 중복 처리 방지, 회수 결과에 따른 초기화·삭제 보호입니다. 이는 컨트랙트 차원의 불변식이나 분산 시스템 전체의 정확히 한 번 실행 보장을 뜻하지 않습니다.

코드상 필수 회수 리워드 기준은 5개이며 지급량은 설정값을 사용합니다. 지갑 암호화는 32바이트 키, 12바이트 무작위 IV, 128비트 인증 태그입니다. 토큰 전송 API 경로와 생성 API 경로가 동일하면 거부합니다. 실제 운영 지급량과 컨트랙트 파라미터의 범위·설정 근거는 별도 확인이 필요합니다.

SOH_DID

자체 컨트랙트 명세는 미확인. 백엔드에서 확인되는 입력 제한·기본값·성공 판정 조건을 별첨 D에 정리했다. 온체인 불변식 및 설정 근거를 대신하지 않는다.

27. 스마트컨트랙트 소스코드

SOH API는 Java/Spring Boot, SOH_DID는 Python/Flask 연계 백엔드입니다. 두 검토 범위에서 자체 스마트컨트랙트 소스, 컴파일러 설정, 컨트랙트 lockfile 및 fork 출처는 확인되지 않았습니다. 별도 블록체인 저장소 또는 제공사에 보유 여부를 확인하고 해당 시 빌드·테스트 지침과 함께 제출해야 합니다. 두 백엔드 소스를 스마트컨트랙트 소스 제출물로 표시하지 않습니다. 각각의 기준 커밋은 말미에 기재했습니다.

28. 배포 스크립트·설정

SOH API

SOH API의 배포 자료는 .github/workflows/deploy-api-prod.yml 및 infra/terraform입니다. 이는 애플리케이션·클라우드 배포 자료이며 컨트랙트 배포 스크립트는 아닙니다. 자체 컨트랙트가 확인되면 해당 배포 순서·초기 파라미터·검증·롤백 자료를 별도로 받아야 합니다.

SOH_DID

백엔드용 main/deploy/ec2/soh-did.service와 soh-did.env.example이 있다. 컨트랙트 배포 스크립트·배포 계획서·롤백 절차는 미확인이다. 설정 파일 제출 시 비밀번호를 제거한 사본을 사용해야 한다. 상세: 별첨 D.

29. 권한 구조 문서

SOH API

SOH API는 JWT와 역할 기반 접근 통제를 사용합니다. /daegu-chain/는 **SUPER_ADMIN**, /admin/는 기본적으로 ADMIN 또는 SUPER_ADMIN 접근이며, 관리자 삭제·비밀번호 초기화·목록 등 일부 기능은 SUPER_ADMIN으로 제한합니다. 사용자 API는 로그인 사용자 문맥을 사용합니다. 세부 기능은 서비스 계층의 기관·사용자 범위 검사를 함께 확인해야 합니다.

컨트랙트 소유자·다중서명 서명자·임계값·타임락은 이 API 역할과 별개이며 확인 필요입니다. 서식6에는 API 역할과 온체인 권한을 나누고, 실제 권한 계정·부여 및 회수 절차를 추가해야 합니다.

SOH_DID

서버 소유자 계정·키 설정과 회수 API의 소유자 키 비교는 확인된다. 역할 기반 권한표, 다중서명 구성, 타임락, 권한 부여·회수 절차는 저장소에서 미확인이다. 별첨 C는 코드의 통제 현황이며 승인된 권한 정책이 아니다. 공식 서식6 및 운영 담당 직무별 매핑은 기업 확인 필요.

통합 확인사항: SOH API를 경유하는 요청과 SOH_DID에 직접 도달하는 요청의 접근 경로를 구분해야 합니다. SOH_DID의 공통 호출자 인증·인가나 상위 게이트웨이·네트워크 차단의 실제 적용은 확인되지 않았습니다.

30. 업그레이드 절차

컨트랙트 프록시 구조·업그레이드 권한·스토리지 충돌 검증은 확인 필요입니다. SOH API의 CI/CD 및 EC2 교체 배포를 컨트랙트 업그레이드 절차로 대신 제출할 수 없습니다. 비업그레이드 구조가 확인되면 해당 없음으로 처리할 수 있습니다.

31. 외부 의존성 현황

SOH API

DaeguChain API: 계정·DID·토큰 등 연동에 사용. 잘못된 주소·조회·처리 결과는 지갑 연결이나 거래 상태 오인에 영향을 줄 수 있습니다. 실제 운영 주체·계약 범위·대체 엔드포인트 확인 필요.

외부 토큰 서버: 토큰 생성·목록·지급·회수 및 회수 시 holder 서명키 해석에 의존. 실패하면 지급·회수 완료 처리에 영향을 줍니다. 코드에는 특정 DID 미발견 오류에 최대 3회, 700ms 간격의 재시도가 있으며 독립 대체 제공사로 전환하는 경로는 확인되지 않았습니다.

다대구 인증·외부 DID 서비스: 인증 결과와 DID 발급에 의존. 장애 시 해당 연동 경로 이용이 제한될 수 있습니다. 일반 ID·비밀번호 로그인도 존재하지만 모든 사용자의 자동 대체 인증 경로를 보장하지 않습니다. 외부 제공사의 법인명·지원 청구·SLA는 기업 확인 필요입니다.

AWS: 웹·API·DB·비밀정보 저장 등 서비스 인프라에 사용. 장애 전환 구성·복구목표·복구시험 기록은 별도 확인 필요합니다. 서식5가 제공되면 의존 대상별로 이 내용을 이관할 수 있습니다.

SOH_DID

DChain API, MySQL, 서버 로컬 파일 저장소와 Python 패키지에 의존한다. 코드의 장애 처리·대체 경로를 별첨 A에 작성했다. 실제 운영 주체·SLA와 공식 서식5는 별도 확인 필요.

32. 노드 설정 자료

SOH 확인 범위에서는 직접 운영 노드 설정을 확인하지 못했습니다. 외부 제공사의 노드 클라이언트·버전, RPC 노출, P2P 구성 및 검증자 키 관리 자료가 필요합니다. 기업의 직접 운영 여부가 확정되기 전에는 '해당 없음'으로 단정하지 않습니다.

33. 폐쇄형·자체 체인 자료

체인 유형·운영 주체 확인 후 적용 여부를 확정해야 합니다. SOH 저장소에서 genesis/chainspec, 합의·채널·MSP·CA·보증 정책 등 체인 운영 자료는 확인되지 않았습니다. 폐쇄형 체인이라면 제공사 보유 자료를 요청해야 합니다.

34. 지갑 구성 자료

SOH API

사용자 리워드 지갑: DID·사용자와 연결되며 주소 및 암호화 개인키를 서버 DB에 관리하는 구조입니다. 토큰 운영자 지갑: 지급·회수 업무에 사용되는 운영자 주소·개인키 설정이 존재합니다. 외부 토큰 서버가 수행하는 실제 서명 환경과 키 조회 범위는 별도 확인이 필요합니다.

핫·웜·콜드 분류, 실제 주소 목록, 중요도, 키 관리자 직무, 벤더 계약 주체는 미확정입니다. 서식7에는 공개 주소만 검증 후 기입하고 개인키·복호화 키는 넣지 않아야 합니다. 서버 온라인 처리 구조는 확인되지만 콜드월렛·HSM·MPC 사용을 확인한 것은 아닙니다.

SOH_DID

서버 소유자 지갑, DID 생성에 연계된 사용자 체인 지갑, DID/VC/VP 서명용 Ed25519 키를 구분할 수 있다. 보관·사용 경로는 별첨 C에 작성했다. 실제 주소, 핫/웜/콜드 구분, 중요도, 벤더 계약과 공식 서식7은 기업 확인 필요.

35. 키 관리 정책·절차

SOH API

구현 확인: 지갑 개인키는 AES-256-GCM으로 암호화하며 매 암호화 시 SecureRandom으로 IV를 생성합니다. 암호화 키는 서버 설정으로 공급하고, 값이 없거나 길이가 올바르지 않으면 처리에 실패합니다. DB 자격증명은 RDS managed Secret과 Secrets Manager JDBC 연동을 사용하도록 운영 지침에 정의되어 있습니다.

미확인: 지갑 키 생성기의 엔트로피, 입회·승인 기록, HSM/KMS/MPC 적용, 키 백업·분산 보관, 복구 시험, 정기 교체, 폐기·매체 삭제 절차. AES 암호화 구현과 DB Secret 사용만으로 지갑 키가 HSM/KMS에 보관된다고 작성할 수 없습니다. 기존 지갑 암호화 키는 임의 교체하면 복호화에 영향을 주므로 별도 이관·복구 절차가 필요합니다.

SOH_DID

서버에서 Ed25519 키를 생성하고 로컬 JSON에 암호화 없이 저장하며 파일 권한 0600 설정을 시도한다. DID 개인키는 DB에도 저장한다. 체인 지갑 키는 외부 API에서 받아 같은 키 파일에 보관한다. 백업·복구·교체·입회·매체 완전삭제 절차는 미확인이다. /did/delete는 파일·인덱스를 삭제하지만 DB 키 삭제를 호출하지 않는다. 상세: 별첨 C.

36. 키 사용·서명 통제

SOH API

확인한 제어는 JWT·역할 기반 접근, 사용자별 리워드 상태와 중복 검사, 지갑 및 운영자 설정 검사, 외부 요청 결과에 따른 성공·실패 처리입니다. 토큰 회수 API는 운영자 개인키를 외부 서버 요청 본문에 포함합니다. 일부 범용 블록체인 API도 키를 취급하므로 점검 범위에 포함해야 합니다.

금액 한도, 출금 주소 화이트리스트, 시간대 제한, 다중 승인, 전용 서명 단말, 독립 검증 화면 및 별도 승인 채널은 확인 필요입니다. 애플리케이션 JWT 인증을 트랜잭션별 다중 승인으로 간주하지 않습니다.

SOH_DID

VC/VP 서명은 Flask 프로세스에서 수행한다. 체인 요청에는 개인키 필드를 DChain API로 전달한다. /token/retrieve는 요청의 송신자·수신자가 서버 소유자 주소와 일치하고 소유자 키가 일치해야 진행한다. 다른 라우트까지 이를 공통 적용하지는 않는다. MFA, 금액 한도, 목적지 허용목록, 단단계 승인, 별도 확인 채널은 저장소에서 미확인이다. 상세: 별첨 B-C.

37. 키 침해 대응

두 작성안 모두 공식 키 침해 대응 정책, 담당 직무·연락망, 긴급 자산 이전, 역할별 승인 및 대응 시험 기록을 확인하지 못했습니다. 운영 담당자와 DID·토큰·체인 제공사가 보유한 절차를 확인해 제출해야 합니다. 배포 전 구성요소는 기업이 승인한 수립 계획으로 대응할 수 있는지 점검기관과 확인해야 합니다.

38. 온체인 연계 백엔드 자료

SOH API

주요 API(아래 경로 앞에 /api 적용): GET /user/rewards/wallet, POST /user/rewards/wallet/connect, GET /user/rewards/transactions, POST /oral-exercise/rewards/button-click, POST /oral-exercise/rewards/reclaim, POST /login/dadaegu, POST /admin/daegu-chain/token/create. 범용 관리자 연동은 /daegu-chain/common/account, /token-20, /nft-721, /point, /did, /timestamp 등으로 구성됩니다. 뒤의 단축 경로들은 모두 /daegu-chain 하위입니다.

지급 흐름: 사용자 인증 → 요청·콘텐츠·토큰 식별 확인 → 기존 지급 및 먹등키 조회 → 리워드 여정 완료 여부 확인 → 지급·거래 기록 준비 → 설정에 따른 외부 토큰 전송 또는 포인트 처리 → 결과 상태 기록 → 성공한 리워드만 내부 잔액 반영. 외부 실패는 오류·실패 상태로 다루며, 토큰 전송 실패 기록은 재시도 분기가 존재합니다.

회수 흐름: 사용자 상품 수령 요청 또는 관리자 초기화·삭제 업무 → 회수 대상 및 기존 완료 회수 검사 → 지갑·운영자 설정·토큰 주소 확인 → 외부 토큰 서버 회수 요청 → 성공·실패 기록 및 잔액·여정 처리. 초기화·삭제는 회수 실패를 무시하지 않는 보호 흐름을 포함합니다. 사용자 수령과 관리자 초기화·삭제는 서로 다른 진입 경로입니다.

자산 이동·발행을 발생시킬 수 있는 코드상 점검 경로: 구강체조 지급, 상품 수령 회수, 관리자 사용자 초기화·삭제 시 회수, 관리자 토큰 생성, 범용 계정 transfer-faucet, token-20 create-mint-burn-approve-transfer-transfer-from, NFT 생성·발행·승인·전송, point 생성·발행·전송. 실제 활성 상태와 외부 효과를 제공사와 대조해야 하며 지급 버튼만 점검 대상으로 삼으면 안 됩니다.

입금 확정·재구성: 리워드 지급 결과를 내부 기록에 반영하는 코드는 있지만, 일반 입금 감시·확정 블록 수·체인 재구성 시 롤백을 수행하는 독립 인덱서 구성은 확인되지 않았습니다. 외부 성공 응답을 체인 최종 확정과 동일하게 간주할 수 없으며, 전송 성공 후 응답 유실·타임아웃 시 재처리 기준도 제공사와 확인해야 합니다.

서명 서버: SOH API가 외부 토큰·체인 API로 요청을 전달하는 경계까지 확인했습니다. 실제 서명 프로세스 격리·접근 계정·권한은 제공사 확인 대상입니다. SOH 측 거부 조건에는 인증·역할 미충족, 누락된 지갑·운영자 설정, 유효하지 않은 요청, 완료된 리워드 여정, 잘못된 전송 경로 설정 등이 있습니다.

인증 콜백: 다대구 암호화 인증 결과를 서버 RSA 키로 복호화하고 필수 정보·형식을 처리하며 CI는 해시로 저장하는 구현입니다. 암호문 복호화 자체가 발신자 서명 검증이나 재전송 방식을 보장하지 않으므로 해당 요건은 연동 명세와 추가 대조해야 합니다. 블록체인 거래 웹훅 검증 체계는 확인되지 않았습니다.

SOH_DID

API 목록, 전송·회수 흐름 및 실패 경로를 별첨 B에 작성했다. 입금 감시·확정 대기·중복 방지·재구성 롤백, 웹훅 검증 처리, 독립 체인 서명 서버는 이 저장소에서 미확인이다. 운영 시스템에 별도 구현이 있는지 확인해야 한다.

계층 연결 확인사항: SOH API에서 미확인이었던 연계 서버 내부 동작은 SOH_DID 별첨 B~C에 보완했습니다. 다만 실제 운영 배포본의 연결 관계가 확정된 것은 아닙니다. SOH API의 먹등키가 SOH_DID와 체인까지 전파되어 중복 거래를 방지하는지, 전송 성공 후 DB 실패·응답 유실을 어떻게 복구하는지 별도 검증해야 합니다.

39. 관리자 콘솔

SOH API

프론트엔드 관리자 메뉴에는 /admin/users, /admin/exercise-progress, /admin/daegu-reward-status, /admin/daegu-chain-usage-logs, /admin/token-management 등이 있습니다. 메뉴 표시와 서버 인가는 별도로 적용되며 서버 역할 제약은 29번을 참고합니다. 로그인은 계정 인증 및 JWT 기반입니다. MFA 적용 여부, 실제 운영 계정 목록, 계정별 권한과 퇴직·직무변경 시 회수 내역은 기업 확인 필요합니다.

SOH_DID

전용 관리자 콘솔, 로그인/MFA, 역할별 권한·계정 목록은 저장소에서 미확인이다. 테스트 웹을 운영 관리자 콘솔로 간주하지 않는다. 근거: S1, S9.

40. 프론트엔드·앱 설정 및 서명 화면

SOH API

React-TypeScript 웹 프론트엔드와 SOH API를 통한 리워드 처리 구조를 확인했습니다. 현재 확인 범위에서는 사용자 브라우저 지갑의 독립 서명 승인 화면, 직접 RPC 접속 및 모바일 개인키 보관을 확정하지 못했습니다. 프론트엔드·앱의 실제 배포 설정에서 체인 ID·컨트랙트 주소·RPC 사용 여부를 확인하고 상품 수령·리워드 승인 화면을 증적으로 제출해야 합니다. SOH 서버 개인키 취급을 모바일 개인키 보관으로 기재하지 않습니다.

SOH_DID

테스트 웹은 http://127.0.0.1:5000의 DID 생성·목록·토큰 전송 API를 호출한다. 응답 JSON을 화면과 콘솔에 표시하며 별도의 서명 승인 화면은 미확인이다. 토큰명 예시 TOKEN_번호는 현재 서버 허용 목록과 불일치한다. 모바일 앱·개인키 저장 코드는 저장소에서 미확인이다. 실제 이용자 서비스 URL·RPC·주소 설정은 기업 확인 필요. 근거: S9, S7.

41. 온체인 모니터링

SOH API

외부 체인 API 요청·응답·성공 여부를 기록하는 감사 로그와 관리자 조회 기능이 있습니다. 민감 필드 마스킹 구현을 포함합니다. 다만 이것은 온체인 이벤트 전용 감시와 동일하지 않습니다. 감시 주소·특권 함수 탐지·이상 거래 임계값·담당자 알림 및 대응 시한은 별도 확인 필요합니다.

SOH_DID

파일 로그와 일부 전송 실패 로그는 있으나 온체인 감시 주소·탐지 규칙·특권 함수 감시·알림 대응 체계는 저장소에서 미확인이다. 파일 로그 로테이션은 1MB, 백업 10개 설정이다. 근거: S1, S3.

42. 긴급 정지 및 사고 이력

SOH API

공식 출금·컨트랙트 긴급 정지 절차, 발동 기준·승인 권한·소요시간과 사고·장애 대장은 확인 필요입니다. 리워드 설정의 token-transfer-enabled 분기에서는 토큰 전송 대신 포인트 처리로 이어질 수 있으므로 단순 설정 변경을 모든 보상·자산 이동의 긴급 정지 기능이라고 볼 수 없습니다. 범용 관리자 API와 외부 제공사 경로까지 포함한 정지 범위를 확정해야 합니다.

SOH_DID

코드에서 별도 출금 중지 스위치나 컨트랙트 pause 기능은 미확인이다. OS 서비스 중지는 가능하더라도 승인된 긴급정지 절차나 외부 체인의 정지를 의미하지 않는다. 실제 대응 절차·소요시간·사고 및 장애 이력은 기업 확인 필요.

43. 기존 감사·점검 자료

두 작성안 모두 기존 스마트컨트랙트 감사, 블록체인 보안점검 보고서 및 미조치 목록을 확인하지 못했습니다. 기업·제공사의 실제 보유 여부, 점검 범위와 미조치 사유를 확인해야 합니다. 테스트 코드·보안 관련 주석 및 본 통합본은 독립 감사 보고서를 대체하지 않습니다.

44. 온체인 잔액·내부 원장 대사

SOH API

내부 리워드 거래의 지급·회수 상태로 잔액을 재계산하는 구현은 있습니다. 이는 온체인 전체 잔액과의 정기 대사 절차를 입증하지 않습니다. 결제·정산 서비스 해당 여부를 먼저 확정하고, 해당하면 대조 주기·최근 실행 기록·불일치 처리 절차를 제출해야 합니다. 구강체조 리워드와 일반 결제·정산 업무를 구분해야 합니다.

SOH_DID

잔액 조회 API와 로컬 사용자 토큰 상태 필드는 있으나 자동 대사·실행 기록·불일치 처리 절차는 미확인이다. increase_balance는 수량 누적이 아니라 지정 컬럼을 1로 설정한다. 회수 경로에는 해당 필드의 차감/초기화가 없다. 결제·정산 서비스 여부 및 별도 원장을 확인해야 한다. 근거: S3, S7.

45. 증적 표본

이번 통합에서 운영 거래·DB·로그를 추출하거나 실제 증적을 검증하지 않았습니다. 점검 수행사가 지정한 지급·회수 표본에 대해 요청·인증 주체·검토·승인·서명·외부 전송·거래해시·SOH API 원장·SOH_DID 상태 반영을 연결해 확보해야 합니다. 실제 존재하는 기록만 제출하고, 테스트·샘플 자료를 실거래 증적으로 간주하지 않습니다.

권한 부여·회수, 키홀더 변경, 모니터링 대응과 해당 시 정산 표본은 기업이 실제 보유 여부를 확인하고 개인정보·비밀값을 마스킹해야 합니다.

46. 점검 환경·접근권

SOH API

SOH 백엔드 검토 대상은 Senior-Oral-Healthcare-api 저장소이며 기준 커밋은 문서 말미와 같습니다. 읽기 전용 접근권 또는 검증된 소스 스냅샷 제공 방식으로 협의할 수 있습니다. 이번 작업에서 접근권을 부여하거나 외부로 소스를 전송하지 않았습니다. 폐기된 AWS dev 환경을 테스트넷 제공 환경으로 기입하지 않아야 하며, 테스트 체인·포크 환경은 별도 확인해야 합니다.

SOH_DID

저장소는 https://github.com/hanathomastone/SOH_DID이며 기준 커밋은 문서 말미에 명시했다. 읽기 전용 권한 부여, 테스트망/포크 환경 제공은 별도 협의 사항이다. 현재 코드에 민감한 기본 설정값이 있어 외부 제공 전 소스와 이력의 비밀정보 검토가 필요하다. 이번 작업에서는 접근권을 부여하지 않았다.

47. 자료반출 구분표

서식3 작성 기초안: 문서·코드 구조·API 목록·비밀값 제거 설정은 반출 검토 대상, 개인키·암호화 키·JWT secret·API 토큰·DB 비밀번호 원문은 반출 제외 대상, 개인정보·운영 로그·주소·계정 상세는 마스킹 또는 현장 열람 협의 대상으로 제안 합니다.

SOH_DID 작성안은 민감한 기본 설정값이 코드에 포함되어 있다고 기록하므로 원문·이력 제출 전 비밀정보 검토가 필요합니다. 최종 분류·승인과 별도 서식은 기업에서 확정해야 합니다.

정보시스템 점검 · 48~51

48. 주요 시스템 상세정보

SOH API

서버: Amazon Linux 2023 기반 EC2 Auto Scaling 구성, Java 17. 실제 EC2 수량 확인 필요. 운영 Windows 서버는 확인 범위에서 식별되지 않았습니다.

DBMS: RDS MySQL 구성. 저장소 지침의 운영 승인 버전은 8.4.10이며 실제 적용 버전·인스턴스 수는 별도 확인 필요.

웹 서비스: Spring Boot 3.5.16과 starter-web 기반 내장 서블릿 컨테이너 구조. 실제 Tomcat 버전은 배포 산출물 의존성 기준 확인 필요. 독립 Apache-Nginx-IIS 운영 여부와 수량은 확인 필요.

보안·네트워크: VPC, 서브넷, Security Group, ALB, NAT Gateway, S3 Gateway Endpoint 등 AWS 구성.

WAF·VPN·IDS·IPS 및 별도 네트워크 장비 수량은 확인 필요이며 Security Group을 전용 보안장비 수량으로 환산하지 않습니다.

가상화: AWS 관리 인프라를 이용합니다. 자체 ESXi·vCenter·KVM 등 관리 장비 보유 여부는 확인 필요. 클라우드: AWS, 서비스 종류는 13번 참조. 모든 수량은 운영 인벤토리로 확정해야 합니다.

SOH_DID

확인 가능 기술은 Python/Flask, Gunicorn, MySQL(PyMySQL 1.1.1 동봉), Linux/systemd 기반 EC2 배포 예시이다.

Server Windows/Linux 수량, DBMS 버전·수량, Apache/Nginx 등 웹 서버, 방화벽/VPN/IDS/IPS/DDoS/WAF, 네트워크·가상화 장비, AWS 리소스의 실제 종류·버전·수량은 기업 확인 필요. 근거: S7-S8, S11.

49. 정보시스템 점검 스크립트 결과

점검기관 스크립트·가이드가 제공되지 않아 미실행입니다. 자료 제출 안내만으로 운영 서버에서 스크립트를 실행하지 않았습니다. 후속 파일 수신 후 실행 범위·권한·부작용을 확인하여 결과를 수집해야 합니다.

50. 네트워크 장비 Config

직접 운영 네트워크 장비와 제출 대상 확인 필요. AWS 네트워크의 경우 민감값을 제거한 VPC·라우팅·Security Group 등 구성 자료를 대체 제출할 수 있는지 점검기관과 협의할 수 있습니다. 실제 운영 설정을 이번 작업에서 수집하지 않았습니다.

51. 보안장비 사전 질의

후속 질의 파일 및 실제 보안장비 인벤토리 확인 필요. 본 문서의 AWS 네트워크·접근 제어 내용은 기초 답변으로 활용 할 수 있으나, 장비별 설정·수량·운영 책임자는 별도 작성해야 합니다.

기술 별첨 안내

아래 별첨 A~D는 SOH_DID 작성안의 기술 상세를 보존한 내용입니다. 별도 표기가 없으면 Flask 구성요소에 관한 설명이며 SOH API 전체의 동작을 뜻하지 않습니다. SOH API의 상세 지급·회수·인증 흐름은 본문 38번에 통합했습니다.

별첨 A. SOH_DID 시스템·데이터·외부 의존성

A1. 코드에서 확인한 논리 구성

테스트 웹 → Flask API(/did, /token, /common) → DChain HTTPS API → 외부 체인 처리.

Flask API ↔ MySQL: DID/키/지갑주소, 사용자 식별자·상태, 토큰 메타데이터.

Flask API ↔ 로컬 파일: DID 문서, 개인키 파일, DID 인덱스. Flask API → 회전 로그 파일.

/mitum 접두 경로를 제거하는 미들웨어가 있어 /mitum/token/transfer 등의 요청도 같은 라우트로 연결된다. 별도 인증 경계가 아니다. 서버 수·망 분리·방화벽·리버스 프록시는 실제 구성 확인이 필요하다.

A2. 온체인/오프체인 데이터

- 온체인 처리 요청: 체인 계정 생성, 토큰 생성·전송·승인·발행·소각, 기본 통화 전송 등. 최종 온체인 기록 필드와 확정 규칙은 DChain 구현·응답 및 운영 증적으로 확인해야 한다.
- 오프체인 파일: dids/*.did.json, keys/*.key.json, index.json. DID 문서·생성시각·label·계정주소 및 DID/지갑 키를 저장한다.
- 오프체인 DB: DID 테이블의 DID/개인키/공개키/주소, user 테이블의 식별자·영상별 상태·credential 관련 필드, Token 테이블의 컨트랙트 주소·공급량·API 응답 메타데이터, keyValue 테이블.
- VC/VP: API 요청·응답에서 JWT를 처리한다. 현재 로컬 발급/생성 경로에 JWT 영구 저장 호출은 확인되지 않는다.
- DID 생성은 로컬 did:key 생성이며 DID 문서를 체인에 등록하는 호출은 이 경로에서 확인되지 않는다. 체인 지갑 생성과 구분한다.

A3. 외부 의존성 및 장애 영향

- DChain: 지갑 생성·토큰/체인 조회·변경 요청의 핵심 의존성. 응답이 잘못되면 주소·토큰 메타데이터 및 성공 판단에 영향을 준다. 기본 timeout 20초, timeout은 504, 연결/요청 오류는 502로 반환한다. 대체 API·자동 failover·거래 재시도 규는 미확인이다. 실제 운영 사업자·지원체계는 별도 확인 필요.
- MySQL: DID/사용자/토큰 저장에 사용한다. 연결 재확인·재접속 처리가 있다. DID 저장 실패 시 DB 트랜잭션을 rollback하지만 이미 생성된 체인 지갑과 파일을 취소하지는 않는다. DB 복제·백업·대체 경로는 미확인이다.
- 로컬 디스크: 키가 없거나 잘못되면 DID/VC/VP 서명 및 레거시 회수에 영향을 준다. DID 인덱스는 임시 파일 교체와 프로세스 내부 lock을 사용한다. 여러 Unicorn 프로세스 간 동기화·공유 파일 운영 방안은 확인 필요.
- Python 라이브러리: Flask, flask-cors, gunicorn, requests, cryptography, PyJWT. requirements는 버전을 고정하지 않는다. PyMySQL 1.1.1은 vendor에 동봉되어 있다. 실제 설치 버전은 실행환경에서 별도 확인해야 한다.

별첨 B. SOH_DID API 목록과 자산 이동 흐름

B1. 등록된 API 목록

다음 목록은 소스의 라우트 등록을 정적으로 추출한 범위이다. /mitum 접두 경로도 지원한다.

- DID 생성: POST /did/create, /did/create_account, /did/signup.
- DID 관리: GET /did/dids; POST /did/resolve, /did/delete.

- VC/VP: POST /did/issue-vc, /did/verify-vc, /did/present-vp, /did/verify-vp.
- 토큰 변경: POST /token/create, /token/transfer, /token/approve, /token/transfer_from, /token/retrieve, /token/mint, /token/burn, /token/upload_token.
- 토큰 조회: POST /token/balance, /token/balance_list, /token/supply, /token/allowance; GET/POST /token/tokens, /token/token_list; GET /token/local_tokens.
- 공통 설정: GET /common/endpoints, /common/dchain_config.
- 체인 조회: GET/POST /common/node_info, /common/chain_id, /common/rpc_node, /common/block_number.
- 계정/블록/거래 조회: POST /common/acc_balance, /common/acc_info, /common/block_by_hash, /common/block_by_num, /common/trx_info, /common/trx_count.
- 계정/자산 변경: POST /common/acc_create, /common/acc_faucet, /common/cur_transfer.

B2. 토큰 전송 흐름과 실패 분기

요청 → token_name 정규화·허용 목록 검사(지정한 경우) → user_DID로 수신 주소 조회(지정한 경우) → 토큰 컨트랙트 조회(이름만 지정한 경우) → 송신자·키 기본값 보완 → DChain 요청 → HTTP 200 및 state=OK 확인 → DID와 token_name이 있으면 사용자 상태 컬럼을 1로 설정 → DB commit → 응답.

- 거부 조건: 허용되지 않은 token_name은 400, 찾을 수 없는 user_DID는 404, 이름으로 찾을 수 없는 컨트랙트는 400이다.
- 외부 전송 실패: 실패 로그를 남기고 외부 응답 또는 프록시 오류를 반환한다. 이 경우 로컬 상태 갱신은 하지 않는다.
- 외부 전송 성공 후 DB 실패: 외부 거래와 로컬 DB를 묶는 원자적 트랜잭션·보상 처리·재처리 기록은 미확인이다. DB 오류가 발생해도 외부 거래가 취소되는 것은 아니다.
- 상태 갱신은 전송 수량과 무관하게 1을 기록한다. 지급 완료 상태와 실제 잔액을 구분해야 한다.

B3. 회수 흐름과 실패 분기

POST /token/retrieve → 송신자/수신자 주소가 서버 소유자와 일치하는지 검사 + sender_pkey 비교 → 불일치 시 403 → holder의 로컬 지갑 키 탐색 → 키가 있으면 해당 계약·요청 수량에 대해 소유자 allowance 승인 → 승인 성공 시 transfer_from 호출 → 응답.

승인 실패 시 stage=approve 오류로 종료하며 transfer_from은 호출하지 않는다. 로컬 키를 찾지 못하면 추가 approve 없이 기존 transfer_from 프록시로 진행한다. 승인 성공 후 전송 실패 시 allowance 취소·보상 흐름은 확인되지 않는다. /token/transfer_from을 직접 호출하는 경로에는 /retrieve의 소유자 비교 분기가 적용되지 않는다. 실제 외부 검증 정책은 별도 확인 대상이다.

B4. 자산 이동 및 거래 유발 후보 경로

- 직접 이동 요청: /token/transfer, /token/transfer_from, /token/retrieve, /common/cur_transfer.
- 공급량·승인 변경: /token/create, /token/mint, /token/burn, /token/approve. retrieve 내부에서도 approve가 호출될 수 있다.
- 기타 체인 변경 후보: /common/acc_create, /common/acc_faucet, DID 생성 3개 별칭의 지갑 생성 호출, /token/upload_token. 실제 거래 생성 여부와 영향은 외부 API 구현에 따라 확인 필요.
- 입금 처리: 잔액·거래 조회 프록시는 있지만 입금 watcher, 확정 블록 수 기준, 중복 처리 키, 재구성 롤백 및 웹훅/콜백 검증 라우트는 미확인이다.

별첨 C. SOH_DID 키·지갑·권한 현황

C1. 용도별 키 인벤토리 초안

- DID 서명 키: Flask 프로세스에서 `Ed25519PrivateKey.generate()`로 생성. cryptography 라이브러리에 난수 생성을 위임하며 별도 엔트로피 장비·입회 기록은 미확인. DID 문서·VC·VP 기능에 사용한다. 개인키는 hex 문자열로 JSON과 DID 테이블에 저장한다.
- 사용자 체인 지갑 키: DChain /com/acc_create 응답에서 수신. DID 키 파일의 wallet 객체에 주소·공개키·개인키를 함께 저장한다. 레거시 회수의 allowance 승인에 사용한다. 외부 키 생성 환경과 알고리즘은 코드만으로 확인할 수 없다.
- 서버 소유자 체인 키: DCHAIN_OWNER_PRIVATE와 DCHAIN_OWNER_ADDR 설정을 사용한다. 토큰 생성·발행·전송의 기본값과 회수 인증에 관여한다. 기본 비밀값이 코드에 포함되어 있어 제출본에는 값을 실지 않았다.

C2. 저장·노출·삭제 동작

저장 경로는 DID_DATA_DIR → DATA_DIR → ./data 순으로 결정된다. 키 파일은 JSON 직렬화로 저장하고 파일 권한 0600을 시도하지만 실패를 무시한다. 실제 OS ACL, 디스크/DB 암호화, 백업 접근권은 별도 확인이 필요하다. HSM/KMS/MPC 연계는 이 저장소에서 확인되지 않는다.

DID 생성 성공 응답에는 DID 개인키와 체인 wallet 객체가 포함된다. 테스트 웹은 응답 전체를 화면과 콘솔에 출력하므로 키도 출력될 수 있다. 회수 API에서 키를 직접 반환하지 않는다는 사실을 전체 API의 키 비노출 정책으로 확대해서는 안 된다.

/did/delete는 DID 문서·키 파일·인덱스를 삭제한다. DB의 DID/user 행, 복제본·백업, 클라이언트에 전달한 키의 폐기를 처리하지 않는다. 파일 unlink는 매체 완전삭제의 증거가 아니다.

C3. 구현된 통제와 확인할 통제

- 공통 DChain 연계: 클라이언트가 넘긴 token/chain 대신 서버 설정을 사용한다. 이는 외부 서비스 호출 인증이며 앱 호출자의 로그인·업무 권한 확인을 의미하지 않는다.
- retrieve 전용 통제: 송신자·수신자 주소 비교 및 hmac.compare_digest를 이용한 소유자 키 비교. 다중서명/MFA/분리 승인에 해당하지 않는다.
- 기타 기능: Flask 등록 코드와 라우트에서 공통 사용자 인증·역할 기반 권한 검사는 미확인이다. API Gateway·네트워크·상위 서비스의 별도 통제는 기업 확인 필요.
- 체인 서명: 본 앱은 private key 필드를 외부 DChain으로 전송한다. 외부 서명 서버의 실제 구성·격리·권한은 미확인이다. 로컬 VC/VP 서명은 API 프로세스에서 실행한다.
- 로깅: 토큰 전송 실패 로그에 특정 private key 키명을 마스킹한다. 모든 로그·오류 응답·중첩 문자열의 비밀정보 제거가 보장된다고 볼 수 없다.
- 운영 절차: 키 생성 입회·백업·분산 보관·복구 시험·정기 교체·긴급 이전·폐기·승인 채널·담당 직무는 모두 기업 확인 필요.

별첨 D. SOH_DID 파라미터·배포·검증 범위

D1. 코드에서 확인한 조건과 기본값

- 체인 설정: 기본 DCHAIN_CHAIN_NAME=minic, 요청 timeout 20초. 운영 환경변수로 달라질 수 있다.
- 토큰 생성: decimals 미지정 시 9. token_name 정규화 실패를 즉시 거부하지 않고 외부 요청으로 진행하는 분기가 있다.

- 토큰 전송: token_name을 지정하면 ESSENTIAL_VIDEO_1-5 또는 OPTIONAL_VIDEO_1-7로 정규화·제한한다. user_DID가 있으면 amount 미지정 시 1을 사용한다. amount 양수·상한 등의 공통 검증은 이 라우트에서 미확인이다.
- 소유자 기본값: 생성·mint의 owner 및 전송의 sender/key는 setdefault 방식이다. 요청이 값을 지정하면 서버 기본값으로 강제 교체하지 않는다. token/chain의 강제 서버 설정과 구분해야 한다.
- VC/VP: VC 기본 TTL 3600초, VP 기본 TTL 300초. TTL을 정수 변환하며 명시적 허용 상한·양수 제한은 미확인이다. 검증은 EdDSA 및 필수 시간/발급자 클레임을 검사한다. VC audience 검사는 aud가 제공될 때, VP 검증은 aud 필수 조건으로 적용된다.
- 성공 조건: 토큰 생성 저장·전송 후 상태 갱신은 HTTP 200 및 body.state=OK를 사용한다. 독립적인 온체인 확정 확인 기준은 미확인이다.

D2. 배포 예시에서 확인된 값

Linux/systemd에서 ubuntu 사용자-www-data 그룹으로 Gunicorn을 실행한다. 작업 경로 예시는 /opt/soh-did/current, 환경파일은 /etc/soh-did/soh-did.env, 바인딩은 127.0.0.1:5000이다. Gunicorn은 workers 2, threads 4, timeout 60초이며 자동 재시작 설정이 있다. 실제 적용 여부는 미검증이다.

필요 설정 범주는 DCHAIN_BASE_URL/API_TOKEN/CHAIN_NAME/TIMEOUT/OWNER_ADDR/OWNER_PRIVATE, MYSQL_HOST/PORT/USER/PASSWORD/DATABASE, DID_DATA_DIR 또는 DATA_DIR, APP_LOG_DIR이다. 값은 운영 담당자가 안전한 경로로 제공해야 한다.

직접 run.py를 실행하면 0.0.0.0:5000, debug=True로 실행한다. 이것을 운영 배포 설정으로 간주하지 않는다. Python·MySQL·설치 패키지의 실제 버전, 리버스 프록시·TLS·접근 제어와 비밀값 제거 배포본은 별도 확인 필요.

D3. SOH_DID 원문 작성 시 검증 범위

원본 PDF 3쪽과 항목 번호 1-51을 확인하고 라우트·저장 로직·배포 예시를 정적으로 검토했다. 운영 DB/체인 호출, 실제 거래, 운영 서버 점검과 보안 취약점 재현은 수행하지 않았다. 기존 main/tests/test_token_retrieve.py는 확인했지만 실행하지 않았다. 모듈 import 과정에서 DB 초기화가 발생할 수 있으므로 완전한 외부 의존성 격리를 먼저 마련해야 한다.

근거 문서·기준 커밋

- 원문 A: 2026-09-17_SOH_사전요청자료_개발내용_작성안.pdf, 8페이지. SOH API 기준 32877be1e467b2a2937ce4252bca0cc1161cda2d, 프론트엔드 기준 016beb90eeeece00add657dc40b7ed0aab39c017.
- 원문 B: SOH_DID_사전요청자료_작성안.pdf, 8페이지. SOH_DID 기준 9f31eee2ca7a4261279074fd46859e0e74b2a73e.
- 통합 작업 기준 저장소 커밋: 2c6ceb60ef8170559b2af35a8696f7a7c5ccc3bf. 위 커밋들은 각 원문의 검토 기준이며 현재 배포 버전을 보장하지 않습니다.

SOH API 근거 파일

- 서비스·인프라: README.md, AGENTS.md, api_server/build.gradle, infra/terraform, .github/workflows/deploy-api-prod.yml.
- 프론트엔드: 해당 저장소 AGENTS.md, src/components/layouts/admin/AdminSidebar.tsx.
- 아래 Java 경로는 api_server/src/main/java/com/kaii/dentix 기준입니다.
- 권한: global/config/WebSecurityConfig.java. 개인정보·인증: domain/user/domain/User.java, DadaeguUserIdentity.java, domain/user/application/DadaeguLoginService.java.
- 지갑·외부 연계: domain/daeguChain/application/DaeguWalletPrivateKeyCipher.java, DaeguChainApiAuditService.java, domain/daeguChain/client/ExternalTokenClient.java 및 domain/daeguChain/controller.
- 리워드: domain/reward/application/UserRewardService.java, UserRewardReclaimService.java, domain/reward/controller/UserRewardController.java, domain/oralExercise/controller/OralExerciseController.java, domain/admin/controller/AdminUserController.java 및 AdminDaeguChainTokenController.java.

SOH_DID 근거 파일 색인

다음 경로는 검토 기준 커밋의 저장소 루트 기준이다. 비밀값이 포함될 수 있는 파일은 원문을 그대로 외부 제출하지 않는다.

- S1: main/run.py, main/myapp/__init__.py - 앱 등록·미들웨어·로그·CORS·실행 설정.
- S2: main/myapp/routes/did.py - DID 생성·파일/DB 저장·VC/VP·삭제.
- S3: main/myapp/routes/token.py - 토큰 생성·전송·승인·회수·외부 프록시.
- S4: main/myapp/routes/common.py - 체인·계정·블록·거래 API.
- S5: main/myapp/dchain.py - 서버 인증 설정·HTTP 요청·오류 처리.
- S6: main/myapp/utills.py - 외부 주소·체인·엔드포인트·환경변수. 민감한 기본값 포함.
- S7: main/myapp/mysql_db.py, DID_db.py, USER_db.py, Token_db.py 및 각 조회 모듈 - 스키마·데이터 저장/조회.
- S8: main/deploy/ec2/soh-did.service, soh-did.env.example - 배포 예시.
- S9: test_web.html, test_script.js - 테스트 화면·API 호출.
- S10: main/tests/test_token_retrieve.py - 회수 동작 테스트 코드.
- S11: main/requirements.txt, main/vendor/PyMySQL-1.1.1.dist-info/METADATA - 의존성 목록.

제출 전 보완 정보

- 기업: 조직·담당·인원, 서비스명·출시일·사용자 수, 개인정보 처리방침·대상 연령, 인증·점검·사고 이력과 공식 정책.

- 운영: 두 백엔드의 실제 연결 관계·배포 버전·접근 통제, 서버·DB·장비 수량, 키 저장·백업·복구·폐기·승인 절차 및 증적.
- 체인 제공사: 실제 체인 유형·ID·운영 단계, 노드 운영 구분, 계약·지갑 주소, 서명 환경, 거래 확정·재처리·정지·대사 기준.
- 점검기관: 별도 서식1·2·3·5·6·7, 표본 지정, 후속 시스템 점검 스크립트·장비 질의서.

통합 작업 검증 기록

문서 작업만 수행했습니다. 두 PDF의 1~51번 내용을 대조하여 공통 답변을 통합하고 SOH_DID 별첨 A~D를 보존했습니다. 새 소스 분석·운영 접속·실거래·취약점 재현·메일 전송은 수행하지 않았습니다. API·DB·Secret·인프라에는 변경이 없으며 README·AGENTS.md의 관련 사실도 변경하지 않았습니다.

통합 PDF의 한글·번호·줄바꿈·페이지 구성을 렌더링으로 확인하고 git diff --check를 수행했습니다. 문서 작업이므로 앱 빌드·테스트는 생략합니다. 원문 작성 시 테스트 확인과 실행 여부는 별첨 D3에 보존했습니다.

남은 제한은 양쪽 원문의 정적 검토 범위와 실제 운영 간 차이입니다. 통합본 자체가 운영 검증이나 보안 감사 완료를 뜻하지 않습니다. 롤백은 이번 통합 Markdown·PDF 두 파일 또는 해당 문서 커밋만 되돌리면 됩니다. 원본과 기존 작성안은 보존합니다.